Detekcia phishingových e-mailov pomocou CySecBERT

Marek Homiak, Marko Olejník, Hugo Juraj Bulinský, Adrián Polák

Technická Univerzita v Košiciach

Abstrakt Táto práca sa zaoberá detekciou phishingových e-mailov pomocou transformátorových modelov. Porovnávame všeobecný model *BERT-base-uncased* s doménovo špecifickým modelom *CySecBERT* (markusbayer/CySecBERT), trénovaným na kyberneticky orientovaných textoch. Na datasete *zefang-liu/phishing-email-dataset* z platformy Hugging Face sme fine-tunovali oba modely na binárnu klasifikáciu (Safe Email vs. Phishing Email) a hodnotili ich pomocou metrík F1, Precision, Recall, Accuracy a ROC-AUC. Výsledky ukazujú, že CySecBERT prekonáva BERT o +1,02 pp v skóre F1 a o +0,09 pp v ROC-AUC, čím potvrdza hypotézu, že predtrénovaný jazykový model zameraný na kybernetickú bezpečnosť sa lepšie hodí na detekciu phishingu. Analýza chýb pomocou LIME identifikovala kľúčové výrazy zodpovedné za falošné pozitívy a falošné negatíva.

Keywords: phishing detekcia · BERT · CySecBERT · transformátory · klasifikácia textu · kybernetická bezpečnosť

1 Formulácia problému

Phishing patrí k najrozšírenejším formám kybernetických útokov. Útočníci sa vydávajú za dôveryhodné subjekty s cieľom získať citlivé údaje, poverenia alebo finančné prostriedky. Automatizovaná detekcia phishingových e-mailov preto predstavuje kľúčovú zložku moderných bezpečnostných systémov.

Cieľom tejto práce je navrhnúť a vyhodnotiť klasifikátor phishingových e-mailov na báze transformátorových modelov. Konkrétne riešime nasledujúce otázky:

1. Dokáže doménovo špecifický model CySecBERT prekonať všeobecný model BERT-base-uncased na úlohe detekcie phishingových e-mailov?
2. Aké sú typické vzory chýb (falošné pozitívy a falošné negatíva) a aké výrazy ich najviac ovplyvňujú?
3. Sú natrénované modely robustné voči externým (neviditeľným) dátam?

Problém je formulovaný ako binárna klasifikácia textu: vstupom je surový text e-mailu a výstupom je predikcia triedy *Phishing Email* (1) alebo *Safe Email* (0).

2 Teoretický background

2.1 Transformátorové modely pre spracovanie prirodzeného jazyka

Architektúra Transformer [6] revolucionalizovala spracovanie prirodzeného jazyka (NLP) zavedením mechanizmu pozornosti (self-attention), ktorý umožňuje modelu zachytiť dlhodobé závislosti v texte bez rekurentných vrstiev.

2.2 BERT

BERT (Bidirectional Encoder Representations from Transformers) [2] je predtrénovaný jazykový model, ktorý číta text obojsmerne (zľava doprava aj sprava doľava súčasne). Predtrénovanie prebieha na dvoch úlohách: Masked Language Modeling (MLM) a Next Sentence Prediction (NSP). Vďaka tomu BERT zachytáva bohatý kontextový obsah slov, čo ho robí vynikajúcim základom pre dolaďovanie (fine-tuning) na downstream úlohách, ako je klasifikácia textu, odpovedanie na otázky či analýza sentimentu. My používame variant *bert-base-uncased* s 12 Transformer blokmi, 768 skrytými jednotkami a 110M parametrami.

2.3 CySecBERT

CySecBERT [1] je doménovo špecifická varianta BERT-u, ktorá bola ďalej predtrénovaná na rozsiahlom korpuse kyberneticky orientovaných textov (bezpečnostné správy, CVE záznamy, správy o malvéri, phishingové e-maily). Tým model nadobúda hlbšie porozumenie pre odborný slovník kybernetickej bezpečnosti — výrazy ako *credentials*, *verify your account*, *click here* alebo *suspend* sú v tomto kontexte silnými signálmi phishingu.

2.4 Fine-tuning pre sekvenčnú klasifikáciu

Fine-tuning pre klasifikáciu textu spočíva v pridaní lineárnej klasifikačnej hlavy na vrchol CLS tokenu BERT-u, pričom celá sieť sa dolaďuje na cieľovom datasete pomocou cross-entropy straty. Tento postup je štandardný a dobre zavedený v literatúre [2].

2.5 Metriky hodnotenia

Na vyhodnotenie modelov používame nasledujúce metriky:

- **Accuracy** — podiel správne klasifikovaných príkladov.
- **Precision** — podiel skutočných phishingov spomedzi predikovaných phishingov.
- **Recall** — podiel zachytených phishingov spomedzi všetkých skutočných phishingov.
- **F1-score** — harmonický priemer Precision a Recall.
- **ROC-AUC** — plocha pod krivkou ROC, miera schopnosti modelu rozlišovať triedy.

3 Popis datasetu a predspracovanie dát

3.1 Popis datasetu

Na experimentovanie sme použili dataset `zefang-liu/phishing-email-dataset` dostupný na Hugging Face Hub [4]. Dataset obsahuje e-maily označené binárnou triedou:

- **Safe Email** (trieda 0) — legitímne e-maily.
- **Phishing Email** (trieda 1) — phishingové e-maily.

Dataset vykazuje miernu nerovnováhu tried v prospech phishingových e-mailov, čo je charakteristické pre reálne prostredie. Pred spracovaním sme skontrolovali chýbajúce hodnoty (`df.isnull().sum()`) a duplicitné záznamy (`df.duplicated().sum()`).

3.2 Predspracovanie dát

Predspracovanie zahŕňalo tieto kroky:

1. Odstránenie riadkov s chýbajúcimi hodnotami.
2. Odstránenie stĺpca `Unnamed: 0`.
3. Premenovanie stĺpcov na `text` a `label`.
4. Čistenie textu: nahradenie zalomení riadkov medzerami, odstránenie nadbytočných bielych znakov (`re.sub`).
5. Zakódovanie cieľovej premennej: *Safe Email* $\rightarrow$ 0, *Phishing Email* $\rightarrow$ 1.
6. Odstránenie duplikátov (po čistení textu).

3.3 Rozdelenie dát

Dataset bol rozdelený stratifikovanou náhodnou vzorkou so seed 42 na:

- **Trénovaciu množinu** — $\approx 72\,\%$ príkladov.
- **Validačnú množinu** — $\approx 13\,\%$ príkladov.
- **Testovaciu množinu** — $15\,\%$ príkladov.

Stratifikácia zaručuje rovnomerné zastúpenie tried vo všetkých troch množinách. Bol overený nulový prienik medzi trénovacou a testovacou množinou.

4 Metodológia

4.1 Architektúra riešenia

Oba modely (BERT a CySecBERT) boli fine-tunované na binárnu sekvenčnú klasifikáciu pomocou knižnice Hugging Face `Transformers` [7]. Vstupné texty boli tokenizované s maximálnou dĺžkou 128 tokenov (s orezaním dlhších textov a paddingom kratších), pričom každý model mal vlastný tokenizátor:

- BERT: `bert-base-uncased` tokenizátor (WordPiece, 30 522 podslová).
- CySecBERT: `markusbayer/CySecBERT` tokenizátor (rozšírená doménová slovná zásoba).

4.2 Hyperparametre tréningu

Trénovacie argumenty boli zvolené s ohľadom na stabilitu a reprodukovateľnosť (Tab. 1). Reprodukovateľnosť bola zaistená fixovaním seedov vo všetkých knižniciach (`random`, `numpy`, `torch`, `CUDA`).

Tabuľka 1. Hyperparametre tréningu pre oba modely.

Hyperparameter	BERT-base-uncased	CySecBERT
Počet epoch	3	3
Learning rate	1×10^{-5}	1×10^{-5}
Batch size (train)	32	32
Batch size (eval)	32	32
Max. dĺžka sekvencie	128	128
Warmup ratio	—	0,1
Evaluačná stratégia	každá epocha	každá epocha
FP16 (mixed precision)	áno	áno

CySecBERT má navyše warmup ratio 0,1, čo zodpovedá 10 % krokov s postupným nárastom learning rate — štandardná technika pri fine-tunovaní BERT-u.

4.3 Implementácia

Kód implementuje vlastnú triedu `EmailDataset` (dediaca od `torch.utils.data.Dataset`) a funkciu `evaluate_model` v module `utils.py`. Tréner (`Trainer`) z Hugging Face automaticky volí najlepší checkpoint na základe validačnej accuracy (`load_best_model_at_end=True`).

5 Návrh experimentov

5.1 Kontrolovaný experiment: BERT vs. CySecBERT

Hlavným kontrolovaným experimentom (ablation study) je porovnanie modelu BERT-base-uncased (baseline) s CySecBERT za totožných podmienok:

- Rovnaký dataset, rovnaké rozdelenie, rovnaký seed.
- Rovnaké hyperparametre (okrem warmup pre CySecBERT).
- Rovnaká evaluačná pipeline.

Táto konfigurácia umožňuje priamo merať efekt doménovej predtrénovej špecializácie.

5.2 Analýza chýb

Na porozumenie zlyhaniach modelu sme:

1. Extrahovali falošné pozitívy (FP: Safe → Phishing) a falošné negatíva (FN: Phishing → Safe).
2. Použili TF-IDF na identifikáciu top-20 fráz charakteristických pre FP a FN skupiny.
3. Aplikovali LIME (*Local Interpretable Model-agnostic Explanations*) [5] na 10 FN a 10 FP príkladov CySecBERT-u s agregovaním priemerných váh.

5.3 Test generalizácie na externom datasete

Ako doplnkový experiment (model_test.ipynb) sme natrénované modely otestovali na externom datasete `phishing_email.csv` pochádzajúcom z iného zdroja ako trénovací dataset. Účelom bolo overiť, či modely nepretrénujú na špecifika jedného datasetu.

6 Výsledky

6.1 Priebeh trénovania

Oba modely konvergovali stabilne v priebehu 3 epoch. Trénovacia a validačná chyba (cross-entropy loss) klesala monotónne, pričom nebolo pozorované výrazné preučenie — validačná chyba kopírovala pokles trénovacej chyby. Validačná accuracy dosiahla plateau vo 3. epoche. CySecBERT vykazoval o niečo rýchlejší pokles validačnej straty v prvej epoche, čo korešponduje s jeho doménovou špecializáciou.

6.2 Výsledky na testovacej množine

Tabuľka 2 sumarizuje výsledky oboch modelov na testovacej množine.

Tabuľka 2. Porovnanie modelov na testovacej množine.

Model	Accuracy	F1	Precision	Recall	ROC-AUC
BERT-base-uncased	0,9821	0,9834	0,9811	0,9857	0,9963
CySecBERT	0,9893	0,9936	0,9921	0,9951	0,9972
Δ (CySecBERT − BERT)	+0,0072	+0,0102	+0,0110	+0,0094	+0,0009

CySecBERT prekonáva BERT-base-uncased vo všetkých hodnotených metrikách. Najvýraznejší rozdiel je v skóre F1 (+1,02 pp) a ROC-AUC (+0,09 pp).

6.3 Matice zámen

Oba modely dosiahli veľmi nízke hodnoty chýb. CySecBERT zaznamenal menej falošných negatív než BERT, čo je z pohľadu bezpečnosti kritický aspekt — nezachytený phishing predstavuje väčšie riziko ako falošný poplach.

6.4 ROC krivky

Plocha pod ROC krivkou (AUC) pre CySecBERT (0,9972) prevyšuje BERT (0,9963), čo indikuje lepšiu celkovú schopnosť odlišovať triedy pri rôznych prahoch rozhodovania.

6.5 Analýza chýb

Celkový počet chýb CySecBERT-u na testovacej množine bol výrazne nižší ako u BERT-u. Analýza rozdelenia chýb:

- **Falošné negatíva (FN)**: Phishingové e-maily predikované ako bezpečné. Väčšinou ide o sofistikované e-maily bez typických phishingových indikátorov — neobsahujú explicitné výzvy na kliknutie, využívajú dôveryhodný formálny jazyk. TF-IDF analýza odhalila frázy ako *account update*, *security notice* medzi top-20 výrazmi FN skupiny.
- **Falošné pozitíva (FP)**: Legitímne e-maily predikované ako phishing. Typicky ide o firemné notifikácie obsahujúce výrazy (*click here to verify*, *your account*) zdieľané s phishingovými e-mailmi.

6.6 LIME Explainability

Agregované LIME váhy pre 10 FN vzoriek ukázali, že model sa spoliehal na neutrálne slová (napr. *dear*, *customer*) a ignoroval klamlivé frázy. Pre 10 FP vzoriek model priradil vysoké váhy legálnym firemným výrazom. Tieto zistenia naznačujú, že model je citlivý na výrazy typické pre phishing, no niekedy zlyhá pri e-mailoch, ktoré tieto výrazy neobsahujú alebo naopak, legitímnych e-mailoch s korporátnym jazykom.

6.7 Test na externom datasete

Pri testovaní na externom datasete `phishing_email.csv` si oba modely udržali vysokú accuracy (výrazne nad 80 %), čo vylučuje výrazné preučenie na Hugging Face datasete. CySecBERT si udržal vedúce postavenie aj na tomto datasete. Výsledky potvrdzujú robustnosť modelov a ich schopnosť generalizácie.

7 Kritická analýza a diskusia

7.1 Zhrnutie výsledkov

Výsledky jednoznačne potvrdzujú hypotézu, že doménovo špecifický model CySecBERT prevyšuje všeobecný BERT na úlohe detekcie phishingových e-mailov. Doménová predtrénovacia fáza na kyberneticky orientovaných textoch poskytuje modelu lepšie pochopenie špeciálneho jazyka phishingových e-mailov.

7.2 Porovnanie s literatúrou

Dosiahnuté výsledky sú v súlade s trendom v literatúre, kde doménovo špecifické modely konzistentne prekonávajú všeobecné modely v špecializovaných NLP úlohách. Napríklad BioBERT prekonáva BERT v biomedicínskych úlohách [3], podobne ako CySecBERT v kybernetickej bezpečnosti.

7.3 Limitácia metrík

Napriek výbornej celkovej presnosti sú metriky závislé od rozloženia tried v testovacej množine. Reálne prostredie by mohlo vykazovať iné pomery tried (väčšia prevaha legitímnych e-mailov), čo by mohlo ovplyvniť praktickú použiteľnosť. Pre takéto scenáre by bolo vhodné sledovať aj *Average Precision (AP)*.

7.4 Diskusia o LIME explainability

LIME vysvetlenia sú lokálne aproximácie — neposkytnú globálny pohľad na rozhodovací proces modelu. Pre robustnejšiu interpretovateľnosť by bolo vhodné doplniť SHAP alebo gradient-based metódy (napr. Integrated Gradients).

8 Obmedzenia a možnosti ďalšej práce

8.1 Obmedzenia

1. **Dĺžka vstupu**: Maximálna dĺžka 128 tokenov môže orezať dlhé e-maily, čím sa stratia dôležité informácie z tela správy.
2. **Jednojazyčnosť**: Modely sú trénované prevažne na anglickom texte; detekcia phishingu v iných jazykoch by vyžadovala ďalšie adaptácie.
3. **Statický dataset**: Dataset nepokrýva neustále sa vyvíjajúce phishingové techniky — model by mohol zaostávať za novými útokmi.
4. **Absencia metadát**: Model pracuje len s obsahom textu; e-mailové hlavičky (sender, Reply-To, SPF/DKIM) obsahujú ďalšie silné signály.

8.2 Možnosti ďalšej práce

- Otestovať modely s dlhším oknom kontextu (napr. Longformer, 512 tokenov).
- Vyskúšať iné architektúry: RoBERTa, DistilBERT, DeBERTa alebo väčšie kyberneticky orientované modely.
- Integrovať e-mailové metadáta (hlavičky, URL analýza) ako ďalšie vstupné príznaky.
- Testovanie v reálnom prostredí s kontinuálnym učením na nových phishingových kampaniach.
- Experimenty s krížovou validáciou na robustnejšie odhady výkonu.
- Nasadenie modelu do reálneho phishing filter pipeline.

9 Prínos jednotlivých členov tímu

Projekt bol vypracovaný individuálne. Celý kód, experimenty, analýzy a písomná správa sú dielom jedného autora.

Disclosure of Interests. Autori nemajú žiadne konkurenčné záujmy relevantné pre obsah tohto článku.

Literatúra

1. Bayer, M., Kuehn, P., Bhatt, R., Frey, C., Reuter, C.: CySecBERT: A domain-adapted language model for the cybersecurity domain. ACM Transactions on Privacy and Security **26**(2), 1–21 (2022)
2. Devlin, J., Chang, M.W., Lee, K., Toutanova, K.: BERT: Pre-training of deep bidirectional transformers for language understanding. Proceedings of NAACL-HLT pp. 4171–4186 (2019)
3. Lee, J., Yoon, W., Kim, S., Kim, D., Kim, S., So, C.H., Kang, J.: BioBERT: A pre-trained biomedical language representation model for biomedical text mining. Bioinformatics **36**(4), 1234–1240 (2020)
4. Liu, Z.: Phishing email dataset. `https://huggingface.co/datasets/zefang-liu/phishing-email-dataset` (2023), Hugging Face Hub
5. Ribeiro, M.T., Singh, S., Guestrin, C.: "Why should I trust you?": Explaining the predictions of any classifier. In: Proceedings of the 22nd ACM SIGKDD International Conference on Knowledge Discovery and Data Mining. pp. 1135–1144 (2016)
6. Vaswani, A., Shazeer, N., Parmar, N., Uszkoreit, J., Jones, L., Gomez, A.N., Kaiser, L., Polosukhin, I.: Attention is all you need. Advances in Neural Information Processing Systems **30** (2017)
7. Wolf, T., Debut, L., Sanh, V., Chaumond, J., Delangue, C., Moi, A., Cistac, P., Rault, T., Louf, R., Funtowicz, M., et al.: Transformers: State-of-the-art natural language processing. In: Proceedings of the 2020 Conference on Empirical Methods in Natural Language Processing: System Demonstrations. pp. 38–45 (2020)